

0x01

CCO-04.2.01 / 2026.2

Segurança Cibernética

princípios, arquiteturas e o novo cenário dos CTFs

Prof. Paulo Matias

Departamento de Computação — UFSCar

21 de agosto de 2026

8h–12h

A pergunta do curso

SEGURANÇA COMEÇA QUANDO A COOPERAÇÃO TERMINA

Funciona quando todos cooperam

- ▶ entradas bem formadas
- ▶ componentes honestos
- ▶ usuários cuidadosos
- ▶ falhas raras e independentes



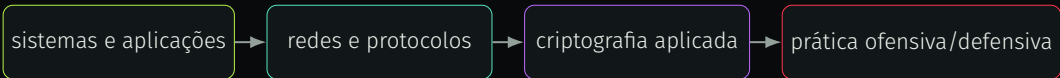
Continua funcionando sob pressão adversarial

- ▶ entradas construídas para confundir
- ▶ componentes comprometidos
- ▶ privilégios abusados
- ▶ falhas encadeadas

01

O que a ementa promete

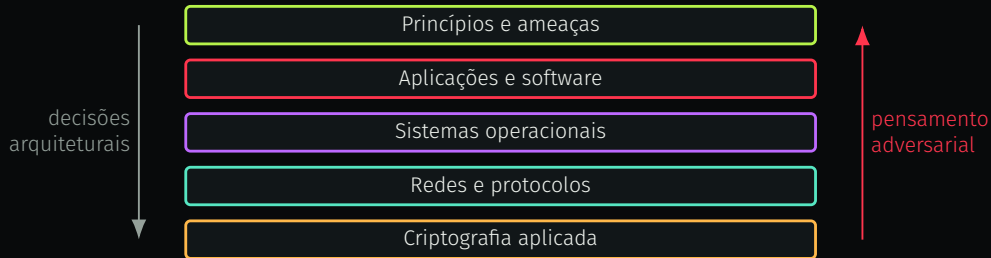
UMA VISÃO INTEGRADA



Não estudaremos “ferramentas de segurança” isoladamente. Estudaremos as propriedades, decisões e fronteiras que fazem essas ferramentas terem sentido.

Fonte: Plano de ensino da disciplina, oferta 2026/2

Mapa do semestre



Fonte: Plano de ensino e calendário da disciplina, oferta 2026/2

Como aprenderemos

Desafio prático é um problema delimitado em que o estudante precisa produzir e explicar uma solução verificável.



Como demonstraremos aprendizagem

O ARTEFATO

- ▶ funciona no ambiente proposto
- ▶ contém evidências do processo
- ▶ explicita fontes e ferramentas
- ▶ pode ser reproduzido

A AUTORIA

- ▶ decisões podem ser defendidas
- ▶ limitações são reconhecidas
- ▶ cada integrante compreende o resultado
- ▶ a IA pode participar; a responsabilidade continua humana

A pergunta não será “você usou IA?”. Será: **você consegue reproduzir, explicar e responder pelo que entregou?**

CTF e flag

CTF é uma competição de segurança organizada em desafios verificáveis.

Flag é uma cadeia de caracteres que comprova a resolução de um desafio.

CTF{prova_compacta_de_sucesso}

O nome vem de *capture the flag*: a bandeira física vira uma prova digital de que o objetivo foi alcançado.

Fonte: Kondo, Mendonça, Smaira e Matias, SBSeg 2021

Dois formatos clássicos

Jeopardy é um formato em que equipes resolvem desafios independentes e acumulam pontos.



Treino de fundamentos
ataque contra o problema

Ataque-defesa é um formato em que cada equipe protege seus serviços enquanto ataca os das demais.



Torneio sob oposição
ataque e operação ao mesmo tempo

Fontes: Analogia visual: treino de kung fu; campeonato de wushu

Categorias: seis maneiras de pensar

Web — falhas em aplicações e protocolos web.

Pwn — exploração de binários para desviar a execução.

Reversing — reconstrução do comportamento de um artefato.

Cripto — análise de construções e usos criptográficos.

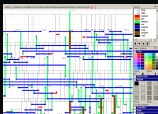
Forense — recuperação e interpretação de vestígios digitais.

Misc — problemas que atravessam ou escapam às categorias.

As categorias organizam habilidades; vulnerabilidades reais raramente respeitam essas fronteiras.

Por que CTF nesta disciplina?

PROBLEMAS ATRAVESSAM DISCIPLINAS



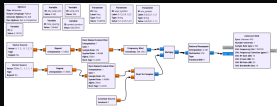
Shift Register · circuitos · 2017



Hardware Trojan · hardware/pwn · 2020



Bletchley Park · autômatos · 2018



WSPR Decoy · rádio/forense · 2021

01

Prática deliberada

uma habilidade por vez

02

Feedback verificável

a flag fecha o ciclo

03

Linguagem comum

artefatos para explicar e colaborar

Placar mede desempenho.

Aprender exige compreender, reproduzir e transferir.

ELT: o exemplo pessoal

EPIC LEET TEAM

- ▶ presença no CTFtime desde 2014
- ▶ nº 1 brasileiro por dez temporadas consecutivas
- ▶ formação interinstitucional: UFSCar, ITA, USP, UFRJ, UFCG, PUC e profissionais de múltiplas empresas
- ▶ organizador do Pwn2Win, 2016–2021
- ▶ Pwn2Win tornou-se classificatória adicional da DEF CON em 2021

Fontes: [CTFtime](#); [Kondo et al.](#), SBSeg 2021

2014

entrada no ranking

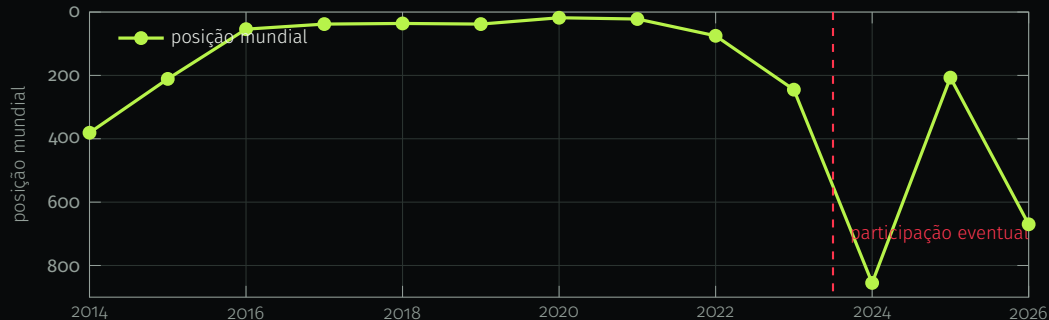
começo do retrato histórico

2020

18º mundial

melhor posição anual

Dez anos no topo brasileiro



No Brasil: nº 1 de 2014 a 2023; nº 3 em 2024–2025; nº 4 no retrato parcial de 2026.

Fonte: Perfil anual do ELT no CTFtime, consultado em 21/08/2026

O gráfico não diz “o time acabou”

O QUE MUDOU

- ▶ menos eventos pontuados
- ▶ participação seletiva
- ▶ energia deslocada ao supertime

O QUE O RATING NÃO MEDE

- ▶ tamanho da comunidade
- ▶ ensino e organização
- ▶ competência fora dos eventos jogados

Uma métrica observada não é automaticamente a propriedade que queremos inferir.

Do time ao supertime

Supertime é uma coalizão temporária de equipes que reúne especialistas e recursos para um evento-alvo.



Fonte: Pwn de Queijo — Linktree oficial

Pwn de Queijo: composição em 2026

EQUIPES

ELT · Ganesh · Duckware · SECRET · VESPAS · GRIS ·
IMEsec · Marcio Herobrine · Boitatech · ACCH ·
FBLi4 · Hacking Club

INSTITUIÇÕES REPRESENTADAS

ICMC-USP · IME-USP · UFSCar · UFRJ · UFPR · UFPE ·
UTFPR · Inatel · UFMG

73 participantes: estudantes do ensino médio à pós-graduação, profissionais e docentes. A composição é dinâmica — este é o retrato publicado para o DEF CON Qualifier 2026.

Fonte: [Cloudlabs/UFSCar, 2026](#)

2025: um salto histórico

17º

lugar mundial

melhor resultado brasileiro no evento

1.691

pontos

DEF CON Qualifier 2025

~60

participantes

coalizão distribuída

~40

presenciais

concentração em São Carlos

Escala social e coordenação já eram parte do desempenho — antes de agentes dominarem a conversa.

Fontes: [Cloudlabs](#); CTFtime; IFSC

2026: escala e resultado

28/686

posição

top 4,1% das equipes

4.583

pontos

quase 3× o placar de 2025

20

solves

categorias variadas

73

pessoas

múltiplas equipes e instituições

A unidade de análise já não é “um jogador”: é uma organização sociotécnica.

Fonte: [Cloudlabs/UFSCar, 2026](#)

Human-led AI é um uso de IA em que humanos mantêm a liderança intelectual e a responsabilidade pelo trabalho.

A IA pode

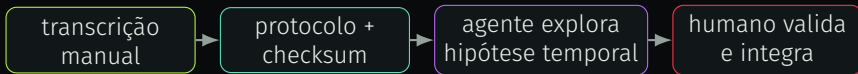
sugerir hipóteses, escrever ferramentas, executar testes e encontrar padrões.

O humano precisa

escolher objetivos, julgar evidência, integrar conhecimento e responder pelo resultado.

Fonte: [Relato do Pwn de Queijo no DEF CON Qualifier 2026](#)

Um solve humano + agente: rfc1149a



Não foi “IA resolveu” nem “humano resolveu sozinho”. A explicação útil identifica **quem produziu qual insight** e como ele foi verificado.

Fonte: Cloudlabs/UFSCar, 2026

CTFtime e rating

Rating é uma pontuação anual ponderada pelos resultados de uma equipe e pelo peso dos eventos.

- ▶ considera os melhores resultados do ano
- ▶ o peso do evento combina participação, edição anterior e voto comunitário
- ▶ permite fotografias comparáveis — não uma medida pura de habilidade

Fonte: Kondo, Mendonça, Smaira e Matias, SBSeg 2021

Placar mundial de 2024

1	kalmarunionen	6	[emoji: gotas]
2	Friendly Maltese Citizens	7	Flat Network Society
3	thehackerscrew	8	Never Stop Exploiting
4	C4T BuT S4D	9	organizers
5	r3kapig	10	Project Sekai

Fotografia de equipes tradicionais antes da ruptura percebida em 2026.

Fonte: [CTFtime — ranking 2024](#)

Placar mundial de 2025

1	r3kapig	6	Project Sekai
2	kalmarunionen	7	Nu1L
3	.i..	8	Infobahn
4	Flat Network Society	9	BunkyoWesterns
5	Never Stop Exploiting	10	thehackerscrew

Mudanças no topo, ainda com forte continuidade de organizações conhecidas.

Fonte: [CTFtime — ranking 2025](#)

Placar mundial de 2026

1	TeamH4C	6	W4llz
2	H-T8	7	r3kapig
3	RubiyaLab Expeditions	8	oxFUN
4	tjcsc	9	krauq
5	Infobahn	10	zod1ak

ANO INCOMPLETO · retrato em 21/08/2026

Fonte: CTFtime — ranking parcial 2026

O que o placar mede agora?

conhecimento de segurança?

coordenação humana?

qualidade do harness?

orçamento de inferência?

3 MINUTOS · ESCOLHA UMA RESPOSTA E DEFENDA-A

2022–2024: IA como copiloto

A LINHA DO TEMPO

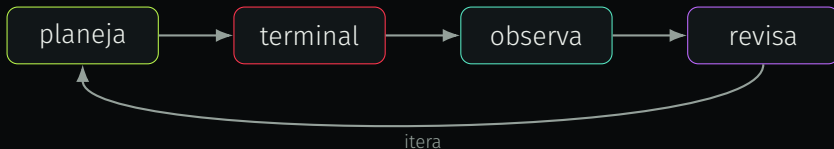


O humano conduz cada ciclo: formular → copiar → executar → interpretar.

22–24

Início de 2025: nasce o agente cotidiano

Ciclo agente é planejar uma ação, usar uma ferramenta, observar o resultado e revisar o plano.



Oferta 2025/2: agentes disponíveis

PRIMEIRO MARCO DA DISCIPLINA

Agentes de terminal já estavam acessíveis, mas **“agentes dominam o CTF competitivo”** ainda não era o ponto de partida da aula inaugural.

Entre esta oferta e a atual, modelos, harnesses, contexto, paralelismo e orçamento mudaram juntos.

25.2

Fim de 2025–início de 2026: mudança qualitativa

ANTES

agente ajuda a resolver

DEPOIS

agente sustenta campanhas inteiras

Competidores relatam desafios médios — e parte dos difíceis — tornando-se solucionáveis autonomamente. Isso é **evidência qualitativa**, não uma taxa universal.

Fontes: [Brian Pak](#); Kabir; krauq

52/52

desafios resolvidos

resultado declarado pela Veria

1º

lugar geral

sistema construído em um fim de semana

- ▶ coordenador central
- ▶ exames paralelos de modelos
- ▶ sandboxes Docker
- ▶ ferramentas de exploração
- ▶ verificação de flags

Fonte: Veria Labs — ctf-agent

Oferta 2026/2: agentes como atores

SEGUNDO MARCO DA DISCIPLINA



Em uma oferta, a pergunta mudou de “posso usar?” para “como aprender, competir e avaliar quando posso delegar?”.

26.2

Agente LLM

Agente LLM é um sistema em que um modelo escolhe e encadeia ações, usa ferramentas, observa resultados e revisa o plano para perseguir um objetivo.

Modelo

produz decisões e linguagem.

Agente

inclui o ciclo, ferramentas, estado e limites.

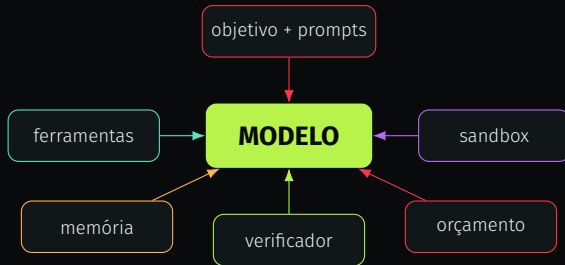
Harness

Harness é a infraestrutura que envolve o modelo e determina ferramentas, contexto, memória, permissões, feedback e coordenação.

Trocar o modelo muda uma peça. Trocar o harness muda **o sistema que transforma tokens em ações.**

Fonte: AgentFlow, 2026

O sistema, não só o modelo



No `ctf-agent`, coordenação paralela e sandboxes foram tão constitutivas quanto o modelo.

Benchmark

Benchmark é um conjunto padronizado de tarefas, ambiente e métrica usado para comparar sistemas sob condições declaradas.

Pode responder

“nestas tarefas, com este orçamento, qual sistema resolveu mais?”

Não garante

transferência, segurança operacional, novidade, custo viável ou desempenho competitivo.

Três lentes de capacidade

CTF

NYU CTF / Cybench

desafios autocontidos e flags

REAL

CyberGym

vulnerabilidades históricas em projetos

LIVE

CTFtime

competição, coordenação e orçamento

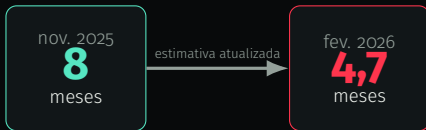
Não some nem compare percentuais de lentes com tarefas, ambientes e métricas incompatíveis.

Fontes: NYU CTF Bench; Cybench; CyberGym; CTFtime

Horizonte de tarefas da AISI

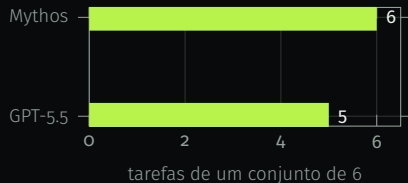
Horizonte de tarefa é o tempo que um especialista humano levaria para tarefas que um sistema conclui com determinada taxa de sucesso.

Tempo estimado para o horizonte dobrar



menor intervalo = avanço mais rápido

Tarefas humanas de ≥ 8 h resolvidas em todas as tentativas



Horizonte a 80% de sucesso · suíte estreita · teto de 12 h · 2,5 M tokens/tarefa. Modelos recentes excederam a curva; não é previsão.

Fonte: UK AI Security Institute

Quando veteranos mudam de comportamento

KRAUQ

experiência solo com agentes e entrada no topo parcial de 2026.

BRIAN PAK

anúncio de retirada tentativa do CTF competitivo diante da mudança de natureza da atividade.

São sinais qualitativos fortes sobre experiência e incentivos — não uma amostra representativa de toda a comunidade.

Fontes: [krauq](#); [Brian Pak](#)

“CTF morreu” é uma tese

PERDA

- ▶ placar deixa de medir habilidade humana
- ▶ atalhos quebram a escada de aprendizagem
- ▶ orçamento compra paralelismo

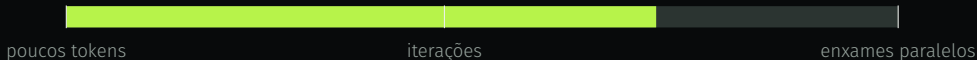
TRANSFORMAÇÃO

- ▶ orquestração vira competência
- ▶ novos desafios podem pressupor agentes
- ▶ revisão humana ganha centralidade

Qual desenho preserva aprendizagem sem fingir que os agentes não existem?

A economia entra no placar

Orçamento de inferência é o limite de tokens, tempo e chamadas disponível ao sistema para perseguir uma tarefa.



Mais computação pode comprar mais tentativas — e confundir capacidade algorítmica com capacidade econômica.

Política de IA desta disciplina

IA É PERMITIDA COM TRANSPARÊNCIA E RESPONSABILIDADE

- ▶ registre fontes, modelos/ferramentas e a contribuição de cada um
- ▶ inclua **somente os prompts que o grupo considerar mais importantes** para enriquecer a discussão
- ▶ preserve evidências suficientes para reproduzir a solução
- ▶ cada integrante deve conseguir explicar, adaptar e defender o resultado

Delegar execução não delega autoria nem responsabilidade.

Acesso e kit inicial — validado hoje



OpenAI Cyber

Daybreak: aprovação
separada



Anthropic CVP

solicitar no portal



OpenCode Go

US\$5 1º mês; depois
US\$10/mês



Harnesses

OpenCode · oh-my-pi

Modelo de pesos abertos é um modelo cujos parâmetros treinados são distribuídos sob uma licença declarada para execução fora do provedor.

- ▶ **Pesos hoje:** Qwen3.8-2.4T-A95B e Kimi K3.
- ▶ **API/Go:** Qwen3.8 Max, Kimi K3 e GLM-5.3; pesos do GLM-5.3 ainda adiados.
- ▶ Auto-hospedar remove controles do provedor — não implica licença irrestrita, zero recusas nem baixo custo local.

Fontes: OpenAI; Anthropic; Qwen; Kimi; OpenCode Go

Segurança

Segurança é a preservação de propriedades desejadas diante de ações acidentais ou adversariais dentro de um contexto.

propriedade + adversário + contexto

Sem os três, “seguro” é apenas um adjetivo.

Ativos e partes interessadas

Ativo é algo de valor que queremos proteger.

Parte interessada é uma pessoa ou organização que atribui valor ao ativo ou sofre as consequências de sua perda.

O mesmo sistema pode proteger ativos conflitantes para partes diferentes.

Propriedade não é mecanismo

Propriedade de segurança é uma afirmação verificável sobre o comportamento que deve ser preservado.

Propriedade

“somente o paciente lê o prontuário”



Mecanismo

senha · ACL · criptografia · log

Confidencialidade

Confidencialidade é a propriedade de que informação não é revelada a entidades não autorizadas.

Um link “difícil de adivinhar” enviado ao destinatário errado preserva o mecanismo — e perde a propriedade.

EM SISTEMA REAL No [Signal](#), mensagens são cifradas de ponta a ponta; o serviço não recebe as chaves que revelam o conteúdo.

Integridade

Integridade é a propriedade de que dados e estado não são alterados ou destruídos de modo não autorizado.

Íntegro

alteração autorizada, mesmo que o valor esteja errado.

Correto

valor representa o mundo — outra propriedade.

Disponibilidade

Disponibilidade é a propriedade de que sistemas e dados permanecem acessíveis e utilizáveis quando requeridos por entidades autorizadas.

Responder “200 OK” não basta: latência, capacidade e dependências integram a utilidade.

EM SISTEMA REAL Um [ReplicaSet do Kubernetes](#) substitui Pods terminados para manter o número declarado de réplicas.

Autenticidade e responsabilização

Autenticidade é a confiança de que uma identidade, mensagem ou origem é genuína.

Responsabilização é a possibilidade de atribuir ações a entidades e exigir que respondam por elas.

Sem identidade, integridade e contexto confiáveis, logs são só texto acumulado.

EM SISTEMA REAL O [AWS CloudTrail](#) registra identidade, horário, origem, parâmetros e resposta de chamadas de API.

Seguro para quem, contra quem e até quando?

EXERCÍCIO ORAL · ESCOLHA UM SERVIÇO CONHECIDO

1. Qual é o ativo — e para qual parte interessada?
2. Qual propriedade precisa ser preservada?
3. Contra quais ações e capacidades?
4. Em qual período e ambiente?

Uma frase completa. Sem usar apenas “seguro”.

Entradas atravessam fronteiras

Entrada é um dado que influencia o comportamento do sistema.

Fronteira de confiança é um ponto em que muda o nível de confiança atribuído a dados ou componentes.

Rede, arquivo, variável de ambiente, sensor, banco e saída de IA: todos podem ser entradas.

Validação

Validação é a verificação de que uma entrada satisfaz regras explícitas.

Sintática verifica forma. **Semântica** verifica significado.

Lista de permissão é um conjunto explícito de formas ou valores aceitos; tudo que não pertence a ele é rejeitado.

EM SISTEMA REAL No PostgreSQL, tipos e restrições como CHECK (`price > 0`) rejeitam estados fora das regras declaradas.

Fonte: OWASP Input Validation Cheat Sheet

Canonicalização

Canonicalização é a conversão de representações equivalentes para uma forma canônica antes de comparar ou validar.

`/public/../../admin → /admin`

Decodifique e normalize uma vez, na ordem correta, antes da decisão.

EM SISTEMA REAL O [AWS Signature Version 4](#) normaliza URI, parâmetros e cabeçalhos antes de calcular e verificar a assinatura.

Parser e interpretador

Parser é um componente que converte uma representação textual em uma estrutura.

Interpretador é um componente que atribui significado operacional a essa estrutura.

Injeção acontece quando dados conseguem alterar a estrutura interpretada como comando.

Parametrização

Parametrização é a vinculação de dados a posições que o interpretador não trata como código.

```
SELECT * FROM users WHERE email = ?
```

O valor ocupa um parâmetro; não recompõe a consulta.

Separar estrutura de dados é mais robusto que tentar reconhecer todo ataque.

EM SISTEMA REAL No protocolo estendido do PostgreSQL, `Parse` envia a consulta e `Bind` fornece os valores separadamente.

Escaping e sanitização

Escaping é a codificação de caracteres especiais para que sejam tratados como dados em um contexto específico.

Sanitização é a transformação ou remoção de conteúdo considerado indesejado.

HTML, JavaScript, CSS, URL e shell têm gramáticas diferentes. Não existe “sanitize()” universal.

EM SISTEMA REAL O **DOMPurify** sanitiza HTML, SVG e MathML usando o parser do navegador e uma lista de permissão; não sanitiza shell.

Codificação de saída

Codificação de saída é a transformação aplicada no momento de inserir dados em um contexto de destino, como HTML, JavaScript ou URL.

Entrada

“este dado faz sentido para o domínio?”

Saída

“como representá-lo sem virar sintaxe?”

EM SISTEMA REAL Templates do [Django](#) codificam variáveis automaticamente para o contexto HTML; outros contextos exigem tratamento próprio.

Uma cadeia, quatro interpretações



PERGUNTA

Onde normalizar, validar, parametrizar e codificar? **Em cada fronteira, para o próximo interpretador.**

Modelo de ameaças

Modelo de ameaças é uma representação estruturada do que protegemos, de quem ou do que protegemos, de como pode falhar e do que faremos a respeito.

ativos → fronteiras → abusos → controles

Fonte: Threat Modeling Manifesto

Ameaça e adversário

Ameaça é uma circunstância com potencial de causar dano.

Adversário é um agente que persegue objetivos conflitantes com os do sistema.

Nem toda ameaça tem intenção: erro humano, incêndio e falha de energia também ameaçam propriedades.

Dano e impacto

Dano é uma consequência negativa para uma parte interessada.

Impacto é a magnitude dessa consequência.

propriedade perdida → consequência → magnitude

Superfície e vetor de ataque

Superfície de ataque é o conjunto de pontos expostos a interação adversarial.

Vetor de ataque é um caminho específico usado para produzir um efeito adverso.

Reduzir superfície elimina caminhos; bloquear um vetor elimina apenas uma maneira de atravessá-la.

Capacidade, motivação e oportunidade

Capacidade é os recursos e conhecimentos disponíveis ao adversário.

Motivação é os incentivos que tornam um objetivo desejável.

Oportunidade é as condições que permitem agir em certo momento.

“Por que alguém faria isso?” não responde “é viável e qual seria o dano?”.

Premissa e precondição

Premissa é uma afirmação tomada como verdadeira dentro do modelo.

Precondição é um estado necessário para que uma ação ou ataque ocorra.

Premissas invisíveis viram vulnerabilidades surpreendentes. Escreva-as para que possam ser contestadas.

Caso de abuso

Caso de abuso é uma narrativa curta de uso deliberadamente contrário ao objetivo do sistema.

Caso de uso

aluno envia um arquivo para correção.

Caso de abuso

aluno envia um arquivo que explora o corretor.

Controle e mitigação

Controle de segurança é uma medida administrativa, técnica ou física que altera o risco.

Mitigação é a redução da probabilidade ou do impacto de um evento adverso.

Um controle pode prevenir, detectar, limitar ou facilitar recuperação — e pode introduzir novos riscos.

Risco residual

Risco residual é o risco que permanece depois da aplicação dos controles.

risco mitigado

residual

Segurança não é risco zero nem uma coleção de controles.

STRIDE: lente, não checklist mágico

STRIDE é uma taxonomia de ameaças: falsificação, adulteração, repúdio, divulgação, negação de serviço e elevação de privilégio.

S identidade falsa
T estado adulterado
R ação negada

I informação divulgada
D serviço indisponível
E autoridade ampliada

Mini-modelagem coletiva

2 MINUTOS EM DUPLAS · CORRETOR AUTOMÁTICO DE TRABALHOS

1. liste dois ativos
2. marque uma fronteira de confiança
3. escreva um caso de abuso
4. proponha um controle e seu risco residual

Depois: uma dupla contesta a premissa de outra.

Isolamento

Isolamento é a restrição das interações possíveis entre componentes ou domínios.

Isolar não torna o componente confiável; limita o que ele consegue afetar quando falha ou é comprometido.

Compartimentos e raio de explosão

Compartmentalização é a divisão de um sistema em domínios independentes.

Raio de explosão é a extensão máxima esperada do dano após uma falha ou comprometimento.

Mais fronteiras úteis $\Rightarrow$ menos autoridade por comprometimento

Processo e espaço de endereçamento

Processo é uma instância de execução com estado e recursos próprios.

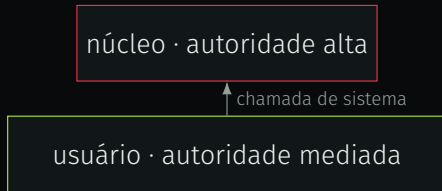
Espaço de endereçamento é o conjunto de endereços de memória acessíveis a uma entidade de execução.

O sistema operacional usa tradução de endereços para fazer cada processo enxergar uma memória privada.

EM SISTEMA REAL O [Chrome Site Isolation](#) coloca sites diferentes em processos sandboxed distintos para limitar vazamentos entre sites.

Níveis de privilégio

Nível de privilégio é um domínio de execução com permissões específicas impostas pelo processador e pelo sistema operacional.



Máquina virtual e hipervisor

Máquina virtual é um ambiente computacional virtualizado com hardware abstrato e sistema operacional próprio.

Hipervisor é o componente que cria e arbitra máquinas virtuais.

A fronteira adicional custa recursos, mas evita compartilhar diretamente o núcleo do host.

EM SISTEMA REAL O **Firecracker** usa KVM para executar microVMs que isolam cargas multi-inquilino no AWS Lambda e no Fargate.

Contêiner

Contêiner é um ambiente de isolamento de processos que compartilha o núcleo do host.

Contêiner

leve · rápido · núcleo compartilhado

VM

fronteira mais ampla · SO próprio · custo maior

EM SISTEMA REAL O **Docker** combina namespaces do Linux para visibilidade e cgroups para contabilizar e limitar recursos.

Sandbox

Sandbox é um ambiente restrito para executar código potencialmente não confiável.

- ▶ sistema de arquivos descartável
- ▶ rede limitada ou ausente
- ▶ credenciais removidas
- ▶ CPU, memória e tempo limitados

Fonte: Veria ctf-agent — uso de sandboxes Docker

Segmentação de rede

Segmentação de rede é a divisão de uma rede em zonas cujos fluxos permitidos são explicitamente controlados.



Permitir fluxos necessários; não conectividade geral.

EM SISTEMA REAL `NetworkPolicy no Kubernetes` seleciona Pods e explicita ingressos e egressos permitidos; políticas vazias realizam *default deny*.

Escape

Escape é a violação de uma fronteira de isolamento que permite afetar o domínio hospedeiro ou vizinho.

Isolamento desloca a confiança: a segurança passa a depender do mecanismo que impõe a fronteira.

Sujeito, objeto e política

Sujeito é uma entidade ativa que solicita uma operação.

Objeto é um recurso sobre o qual a operação é solicitada.

Política de acesso é a regra que decide quais operações são permitidas.

Identidade, principal e credencial

Identidade é um conjunto de atributos que descreve uma entidade.

Principal é uma entidade reconhecida pelo sistema para decisões de segurança.

Credencial é uma evidência apresentada sobre uma identidade ou autoridade.

Autenticação

Autenticação é o processo de verificar uma identidade alegada.

SABE

conhecimento

senha, PIN

TEM

posse

token, chave

É

inerência

biometria

Um fator é evidência; não é a identidade em si.

EM SISTEMA REAL [WebAuthn/passkeys](#) usa uma chave em posse do autenticador e pode exigir verificação local por PIN ou biometria.

Autorização

Autorização é a decisão sobre se um principal pode realizar uma operação sobre um objeto.

autenticado $\nRightarrow$ autorizado

“Sei quem é” e “pode fazer isto” são perguntas diferentes.

Lista de controle de acesso

ACL é uma lista de permissões armazenada junto ao objeto e indexada por sujeitos ou principais.

	ler	escrever	executar
aluno	✓	×	×
corretor	✓	✓	✓

Capacidade de acesso

Capability é uma referência inforjável que confere autoridade sobre um objeto.

ACL pergunta ao objeto
“quem pode me acessar?”

Capability pergunta ao sujeito
“qual autoridade você porta?”

Não confundir com capacidade do adversário: aqui, trata-se de autoridade delegável.

EM SISTEMA REAL No `seL4`, capacidades inforjáveis referenciam objetos do núcleo e carregam direitos de acesso.

RBAC e ABAC

RBAC é controle em que permissões são atribuídas a papéis ou funções organizacionais.

ABAC é controle em que a decisão usa atributos do principal, recurso, ação e contexto.

Papel simplifica administração; atributos expressam contexto — e aumentam a complexidade da política.

EM SISTEMA REAL [Kubernetes](#): Role + RoleBinding. [AWS IAM](#): atributos em tags. [grsecurity](#): RBAC orientado a confinamento do sistema Linux.

Menor privilégio

Menor privilégio é o princípio de que cada sujeito recebe somente as permissões mínimas, pelo tempo mínimo, necessárias à tarefa.

Pergunte sempre: por que precisa? por quanto tempo? em quais objetos? sob qual contexto?

Negação por padrão

Negação por padrão é o princípio de que tudo que não foi explicitamente permitido permanece proibido.

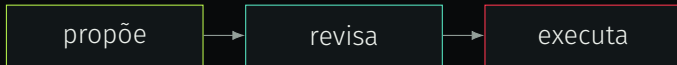
política incompleta $\Rightarrow$ **nega**

A ausência de regra não deve criar autoridade accidental.

EM SISTEMA REAL No **AWS IAM**, toda solicitação começa implicitamente negada; uma permissão explícita é necessária, e uma negação explícita prevalece.

Separação de deveres

Separação de deveres é a distribuição de etapas críticas entre autoridades distintas para que uma só entidade não conclua a ação.



EM SISTEMA REAL No [GitHub](#), uma branch protegida pode exigir que outra pessoa aprove o pull request antes do merge.

Princípio de projeto

Princípio de projeto é uma orientação geral que ajuda a escolher entre arquiteturas e mecanismos.

Princípio orienta julgamento. Não é mecanismo, checklist nem garantia automática.

Menor privilégio é estrutural

Menor privilégio é dar a cada entidade apenas a autoridade mínima, pelo tempo mínimo, necessária à tarefa.

pessoa

acesso temporário

processo

usuário sem root

serviço

conta dedicada

agente

ferramentas
limitadas

Padrões à prova de falha

Padrões à prova de falha é o princípio de basear decisões em permissão explícita, fazendo falhas tenderem à negação.

Se o serviço de política cair, abrir tudo preserva disponibilidade — e destrói controle de acesso. A propriedade prioritária precisa estar explícita.

Mediação completa

Mediação completa é o princípio de verificar toda tentativa de acesso relevante, sem depender de uma decisão antiga que possa ter se tornado inválida.

Caches de autorização precisam de validade, invalidação e contexto tão rigorosos quanto a decisão original.

Economia de mecanismo

Economia de mecanismo é o princípio de manter o desenho tão pequeno e simples quanto possível para permitir entendimento e revisão.

menos estados + menos interfaces = menos surpresas

EM SISTEMA REAL O microkernel `seL4` mantém serviços fora do modo privilegiado e possui provas formais verificadas até a implementação.

Projeto aberto

Projeto aberto é o princípio de não depender do segredo do desenho ou da implementação para obter segurança.

O desenho pode ser público. Os segredos devem ser pequenos, substituíveis e gerenciáveis: por exemplo, chaves.

EM SISTEMA REAL O TLS 1.3 é uma especificação pública: sua segurança depende das chaves, da validação e da implementação — não de ocultar o protocolo.

Separação de privilégios

Separação de privilégios é o princípio de exigir condições ou autoridades independentes para conceder acesso.

Relaciona-se à separação de deveres, mas é mais geral: duas chaves, dois fatores ou duas condições também separam privilégios.

Mínimo mecanismo comum

Mínimo mecanismo comum é o princípio de minimizar mecanismos compartilhados entre usuários ou domínios.

compartilhamento $\Rightarrow$ interferência + canal lateral + impacto comum

Segurança precisa ser usável

Aceitabilidade psicológica é tornar o modo seguro compreensível e conveniente para quem o opera.

Defesa em profundidade é o uso de camadas independentes que limitam a falha de uma única defesa.

Se usuários contornam a defesa, ela não entrega a propriedade.

EM SISTEMA REAL Passkeys/WebAuthn escondem a cerimônia de chave pública atrás do desbloqueio familiar do dispositivo e vinculam a credencial ao serviço.

Fontes: Saltzer e Schroeder, 1975; NIST — defense in depth

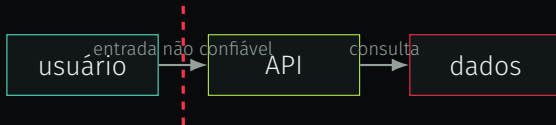
Arquitetura de segurança

Arquitetura de segurança é a organização de componentes, fronteiras de confiança e mecanismos pela qual propriedades de segurança são realizadas.

propriedade → desenho → mecanismo → evidência

Fluxos de dados e fronteiras

Fluxo de dados é o movimento ou a transformação de informação entre processos ou armazenamentos.



Toda mudança de confiança pede uma decisão explícita: validar, autenticar, autorizar, transformar ou isolar.

Monitor de referência

Monitor de referência é um mecanismo que medeia acessos de sujeitos a objetos segundo uma política.

SEMPRE

invocado

não pode ser contornado

FORTE

inviolável

resiste à modificação

PEQUENO

analisável

permite revisão e teste

EM SISTEMA REAL No **SELinux**, operações relevantes no núcleo são interceptadas e confrontadas com a política carregada.

Base computacional confiável

TCB é o conjunto de componentes cuja correção é necessária para que a política de segurança seja cumprida.

A pergunta arquitetural: **quanto código precisa estar certo** para a propriedade continuar verdadeira?

EM SISTEMA REAL O **seL4** reduz a parte privilegiada a um microkernel e verifica formalmente propriedades de configurações específicas.

Aplicação em camadas

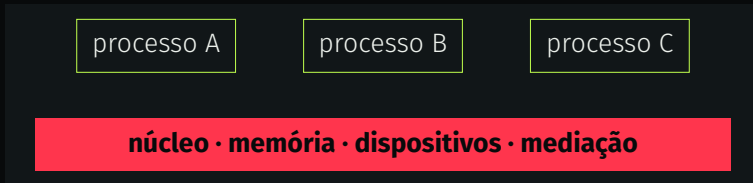
Camada é um agrupamento de responsabilidades com uma interface explícita.



O cliente apresenta identidade; a aplicação autoriza; o banco aplica autoridade mínima própria.

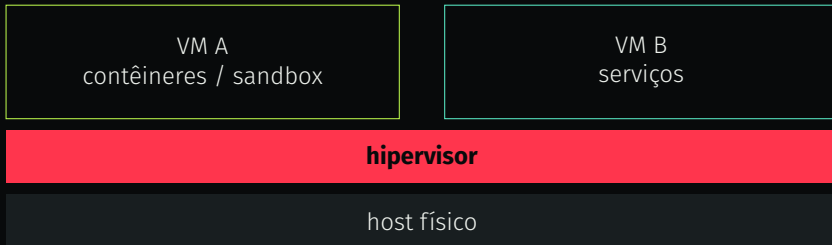
EM SISTEMA REAL O [Row-Level Security do PostgreSQL](#) aplica políticas por linha no banco, mesmo que a aplicação construa uma consulta ampla demais.

Arquitetura do sistema operacional



Processos, memória virtual e chamadas de sistema realizam isolamento — o núcleo integra a TCB.

Arquitetura virtualizada



Escape de sandbox afeta a VM; escape de VM alcança o hipervisor/host. Fronteiras definem o raio.

EM SISTEMA REAL O [Kata Containers](#) preserva a experiência de contêiner, mas executa a carga em uma VM leve com núcleo convidado próprio.

Legado e controle compensatório

Sistema legado é um componente mantido apesar de limitações técnicas ou operacionais que impedem o desenho ideal.

Controle compensatório é uma medida alternativa que reduz risco quando o controle ideal não é viável.

Exemplo: não podemos corrigir o serviço; isolamos a rede, restringimos entradas, monitoramos e preparamos recuperação.

Resiliência

Resiliência é a capacidade de preparar, suportar, recuperar e adaptar-se a falhas e ataques.



Arquitetura segura assume que controles falharão e prepara o próximo movimento.

EM SISTEMA REAL O **Netflix Chaos Monkey** encerra instâncias em produção para testar se os serviços realmente toleram essa falha.

Pwn2Win como arquitetura segura

720

equipes

edição de 2021

94

países

alcance internacional

99,41%

avaliação

comunidade CTFtime

DECISÕES

NIZKCTF · validação offline · isolamento ·
auditoria · evolução iterativa

TENSÕES

segurança × usabilidade
disponibilidade × contenção
abertura × integridade

Escala expõe dependências: melhorar uma propriedade pode piorar outra.

Fonte: Kondo, Mendonça, Smaira e Matias, SBSeg 2021

As cinco perguntas que ficam

1. O que protegemos — e para quem?
2. Contra quem ou o quê?
3. Onde estão as fronteiras de confiança?
4. Quem tem autoridade — e por quanto tempo?
5. O que acontece quando uma defesa falha?

CTFs depois dos agentes

PLACAR

desempenho

sob regras, coordenação e orçamento

AUTORIA

responsabilidade

quem decidiu, verificou e responde

APRENDER

transferência

explicar, reproduzir e adaptar

CTFs continuam excelentes laboratórios — desde que não tratemos essas três coisas como sinônimos.

Próximo passo

ANTES DO PRIMEIRO DESAFIO

- ▶ solicite acesso aos programas OpenAI Cyber/Daybreak e Anthropic CVP
- ▶ prepare um ambiente isolado e descartável
- ▶ leia as regras de IA e escolha como documentará as contribuições relevantes
- ▶ chegue pronto para reproduzir e defender o processo

hack the system · understand the boundary